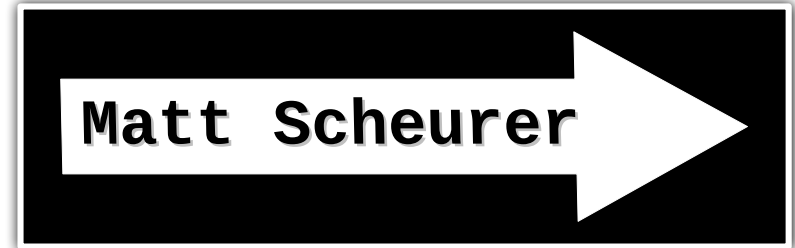
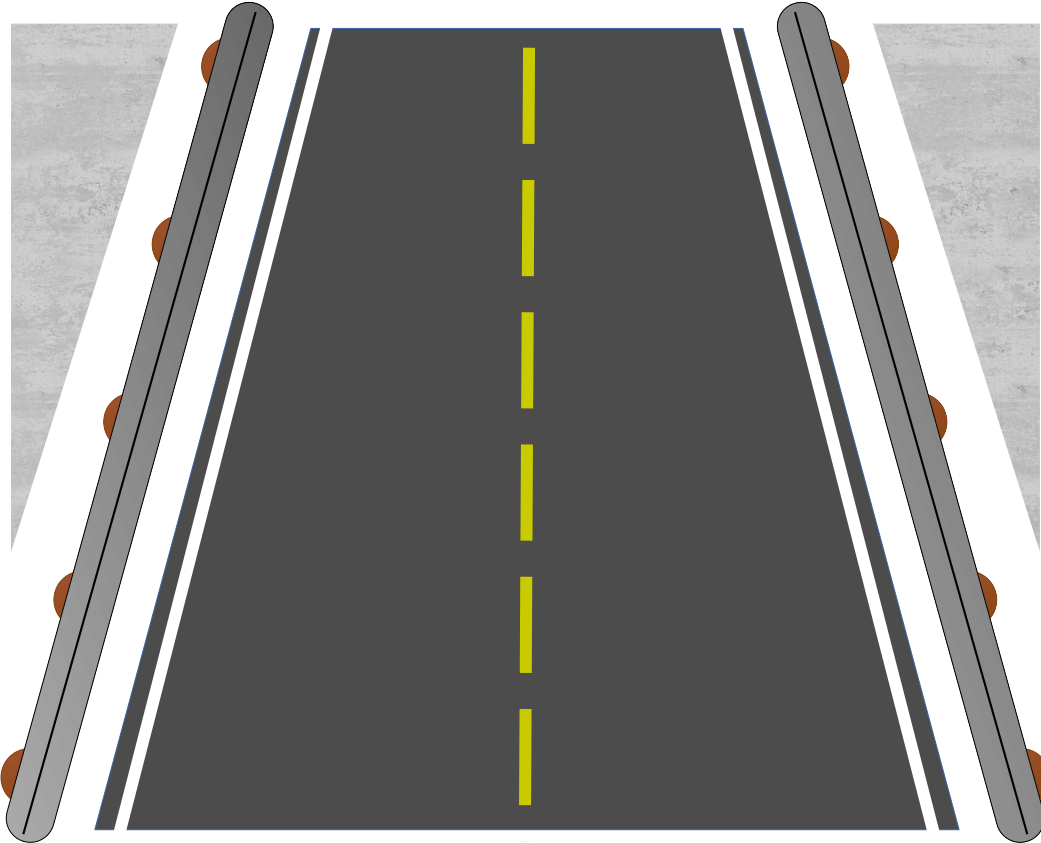


OptivCon Columbus



About Me

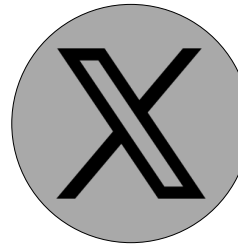
I work for a big well-known organization...



As Vice President (VP) of Computer Security and Incident Response (IR). However, I have many years of hands-on technical experience, including Digital Forensics & Incident Response (DFIR).



<https://www.linkedin.com/in/mattscheurer>



<https://x.com/c3rkah>

Where I volunteer...

I am an Official



Advocate

<https://www.hackingisnotacrime.org>



Advisory Board: Information
Technology and Cybersecurity

<https://www.mywccc.org>



Women's Security Alliance
(WomSA) Technical Mentor

<https://www.womsa.org>

Disclaimer!

Yes, I have a day job.
However...

Opinions expressed are based solely on my own independent security research and do not express or reflect the views or opinions of my employer.



Agenda

- Security Essentials
- Cloud Security
- The Software Supply Chain
- Artificial Intelligence (AI)
- Wrap-up

Slide Deck



<https://slides.dfirmatt.com>

GRC

Who here
knows what this
acronym
means?



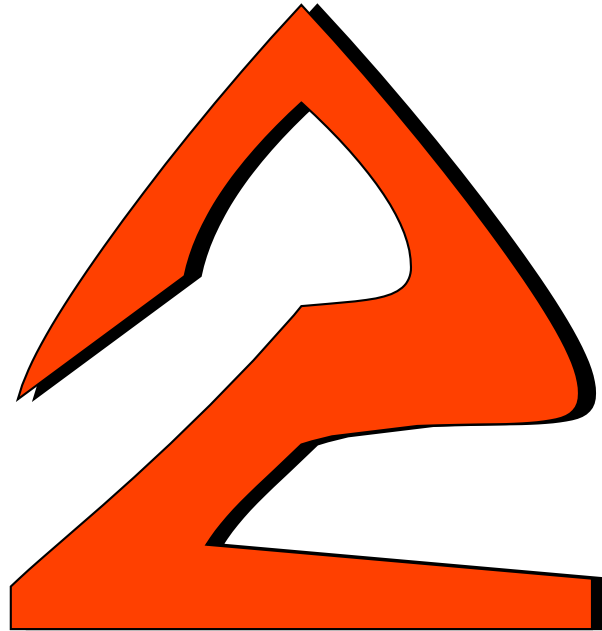
Let's Hear It!!!

Shout it out, on the count of 3...

One,



Two,



Three!



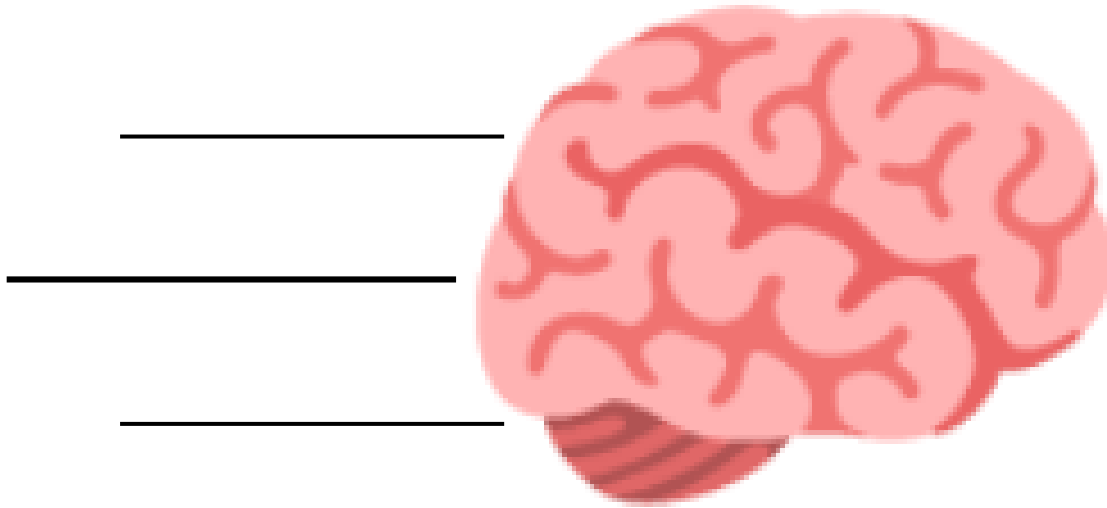


Governance Risk & Compliance

Mindshift



Mindshift



Mindshift



Thinking in terms of

Guardrail

Road-map

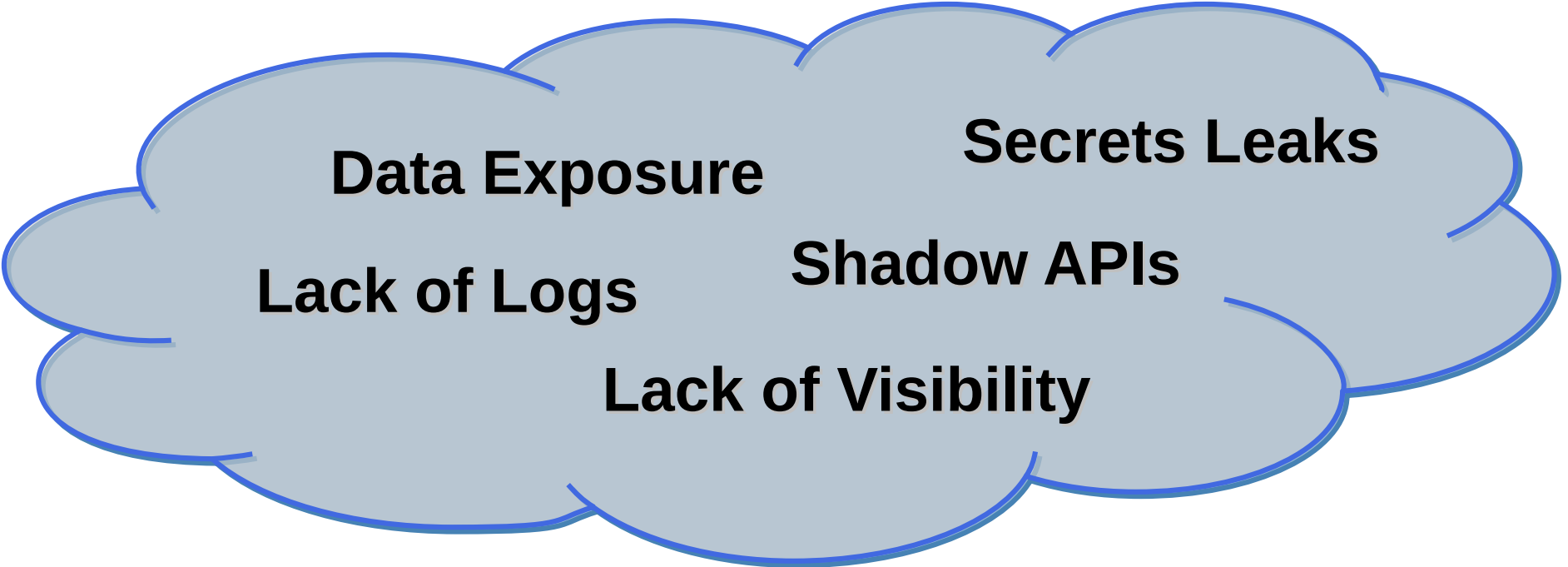
Controls

Essentials

<https://nist.gov/cyberframework>



Cloud Security Issues



Data Exposure

Secrets Leaks

Lack of Logs

Shadow APIs

Lack of Visibility

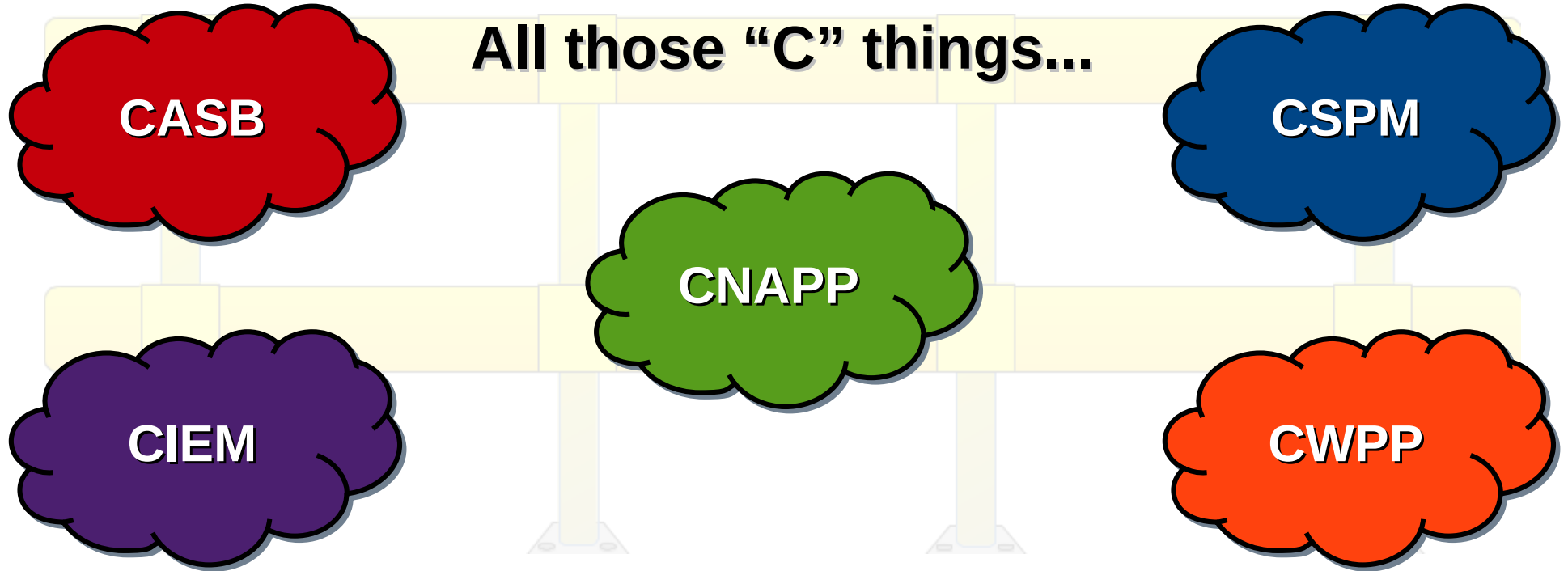
More Cloud Security



<https://youtu.be/0vijJ7r-c8s>

Cloud Security
and Other Assorted
Cautionary Tales

Cloud Security Guardrails



Overarching Security

Cloud-Native Application Protection Platform (**CNAPP**)

- Environments needing holistic protection
- Unified Cloud Security Platform

Account-Level Security

Cloud Application Security Broker (**CASB**)

- Account to Cloud Security
- Monitoring, Detection, and Alerting

Cloud Infrastructure Entitlement Management (**CIEM**)

- IAM
- Enhanced Access Controls

Infrastructure & Activity

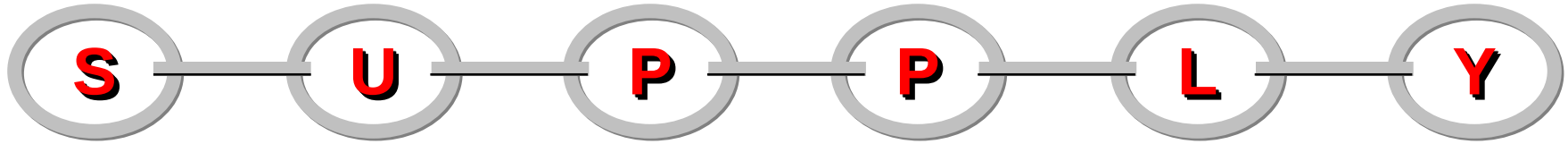
Cloud Security Posture Management (**CSPM**)

- Agentless
- Infrastructure + Configs

Cloud Workload Protection Platform (**CWPP**)

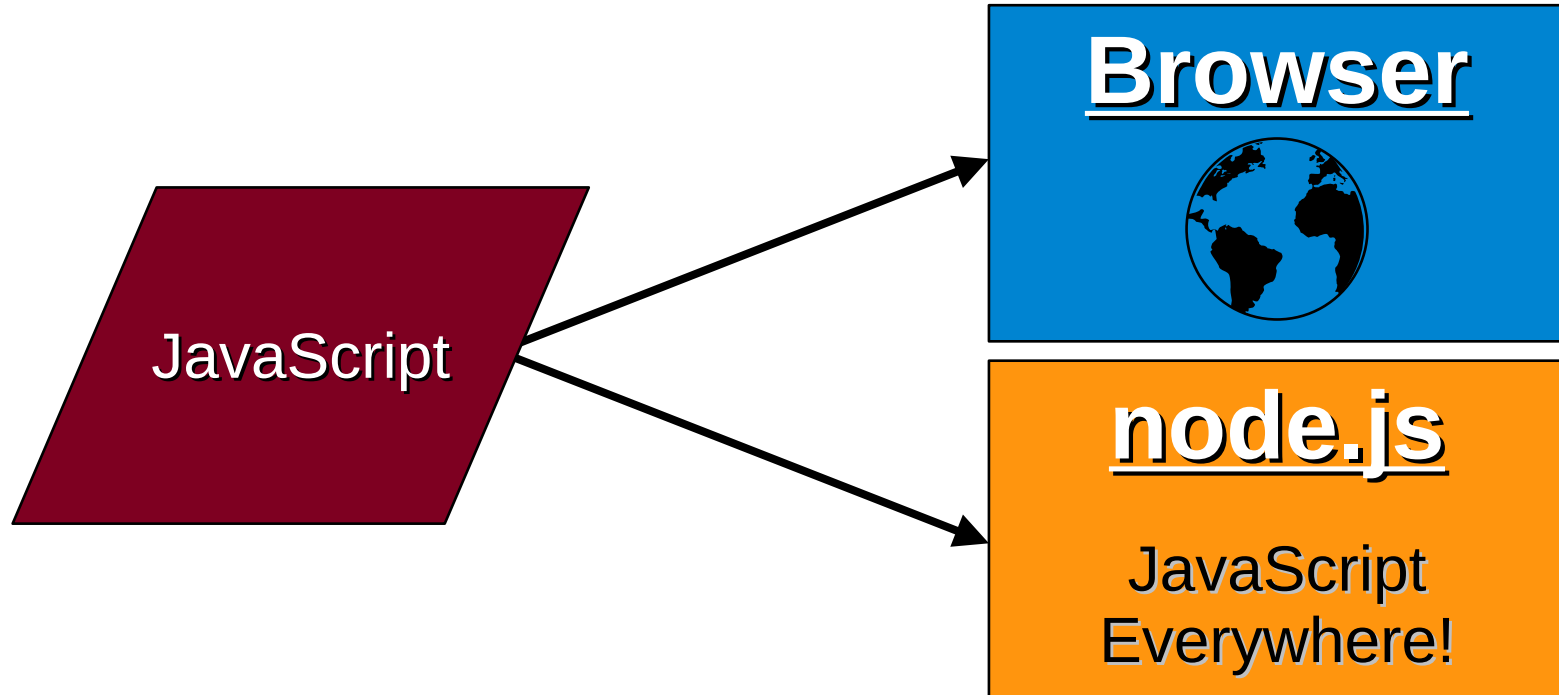
- Agent-based
- Resources + Activity

Software

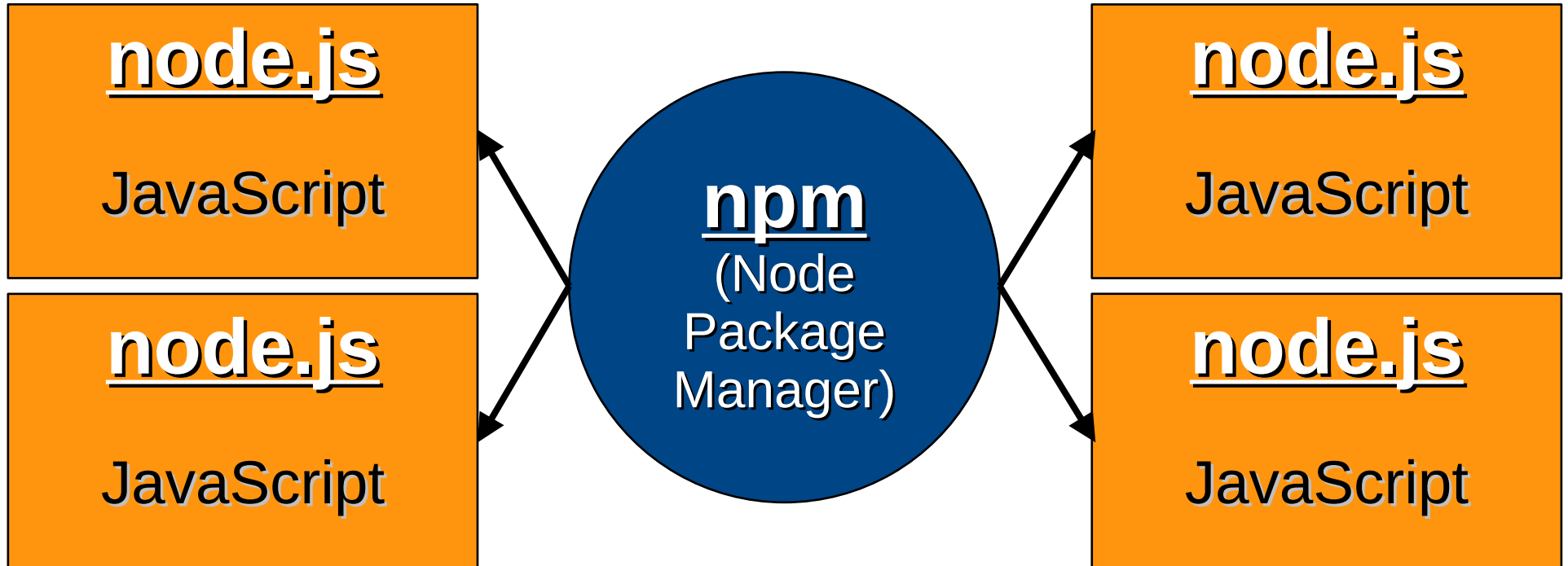


Node.js Example

JavaScript



Node.js Modules



Software

Version Control

package.json

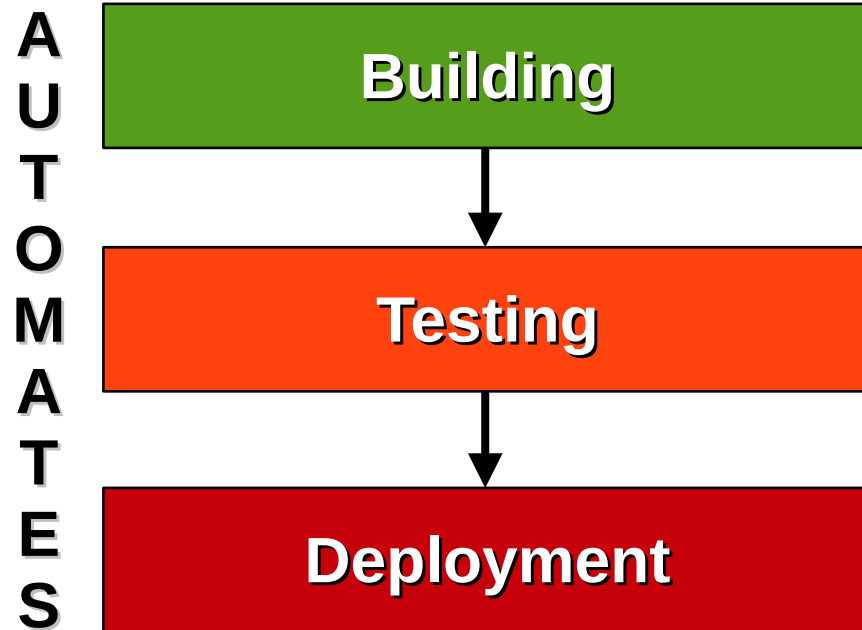


npm

(Node
Package
Manager)

CI/CD Pipeline

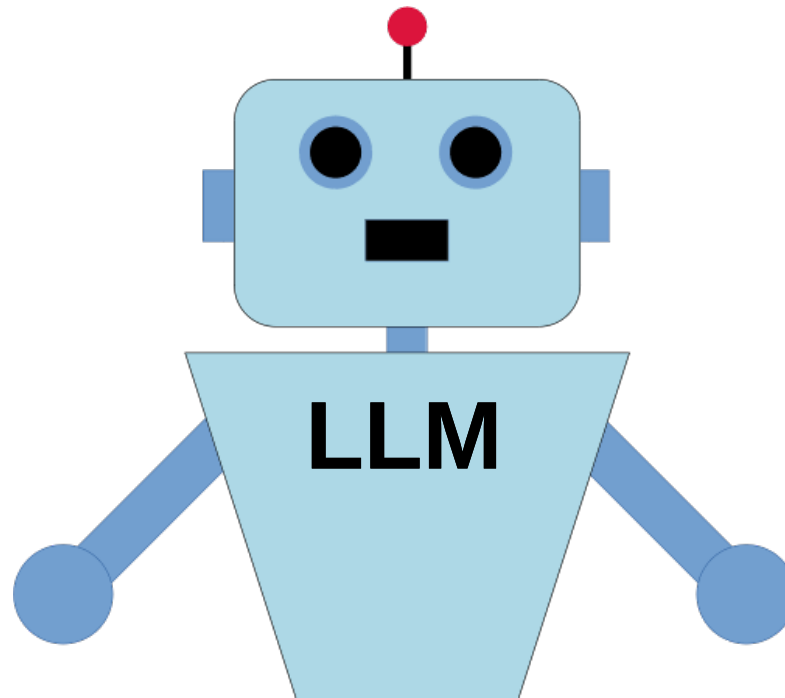
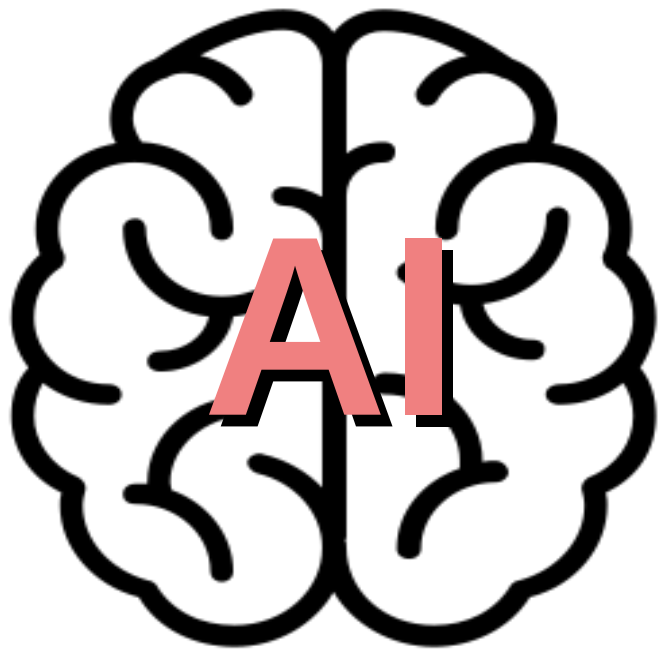
Continuous Integration and Continuous Delivery



Software Supply Guardrails

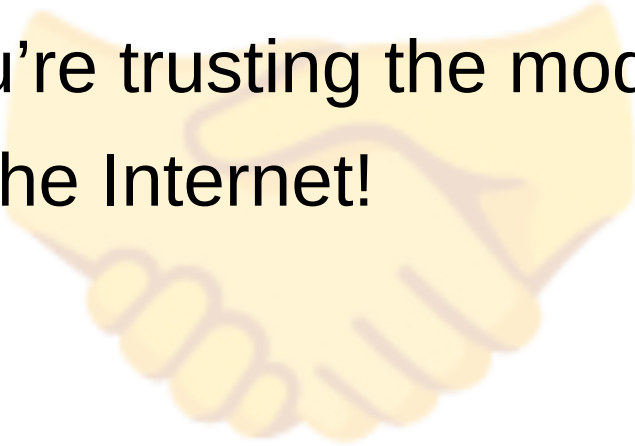
- Use Trusted Sources
- Use Verified Components
- Secure Builds (Pinned Versions, Lock Files, etc.)
- Continuous Monitoring, Enforcement, and Rapid Response

Artificial Intelligence



Generative AI Trust

- Retrieval-Augmented Generation (RAG)
 - Otherwise you're trusting the model itself
 - Or what's on the Internet!



AI Slopsquatting

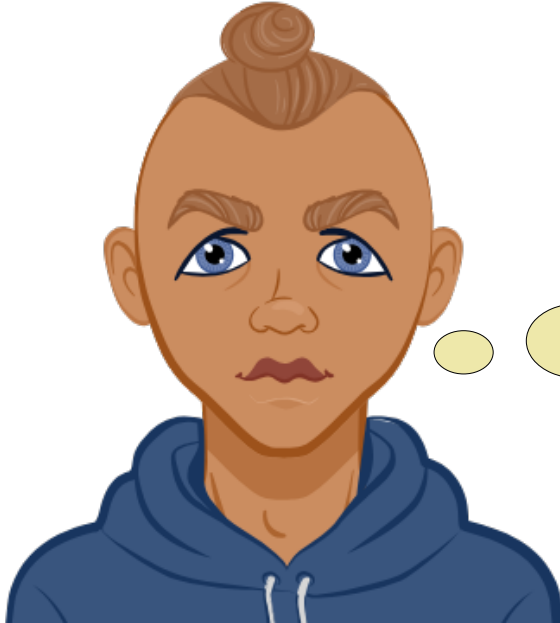
By show of hands...

Who here has heard of
"Slopsquatting"?



Innocent Enough

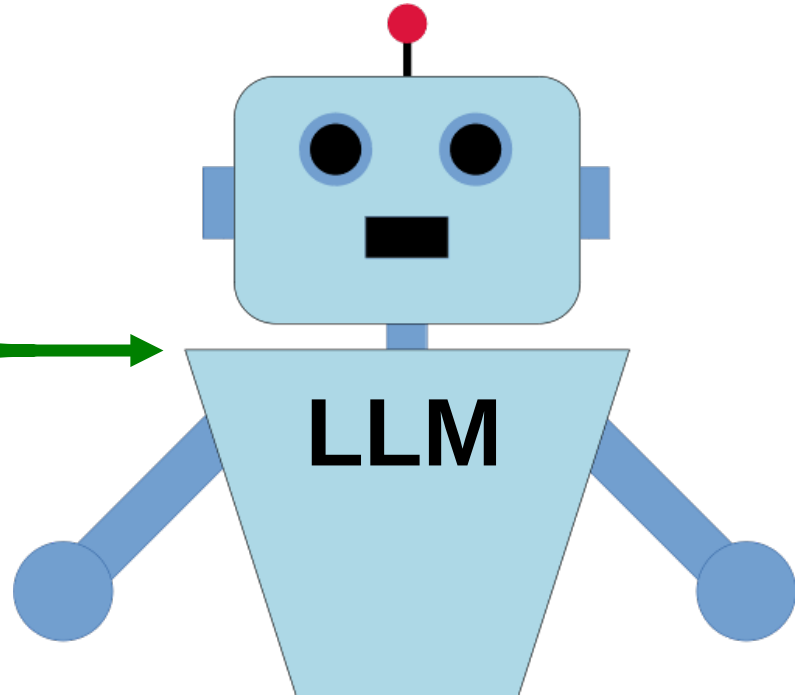
Dev Team Lead



Our sprint
deadline is
looming. Gonna
have to vibe code
this app...

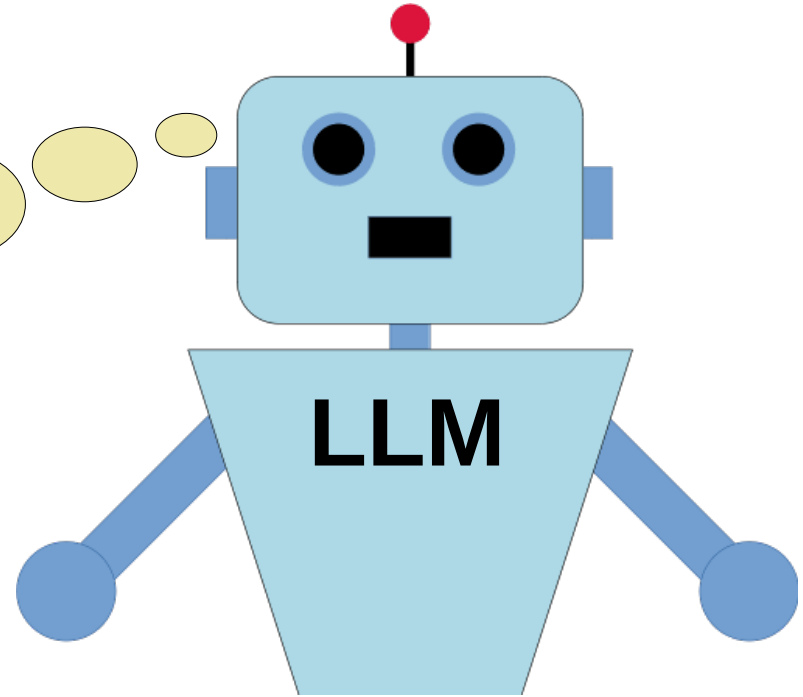
The Request

I need a
python XML
file parser
for this
application

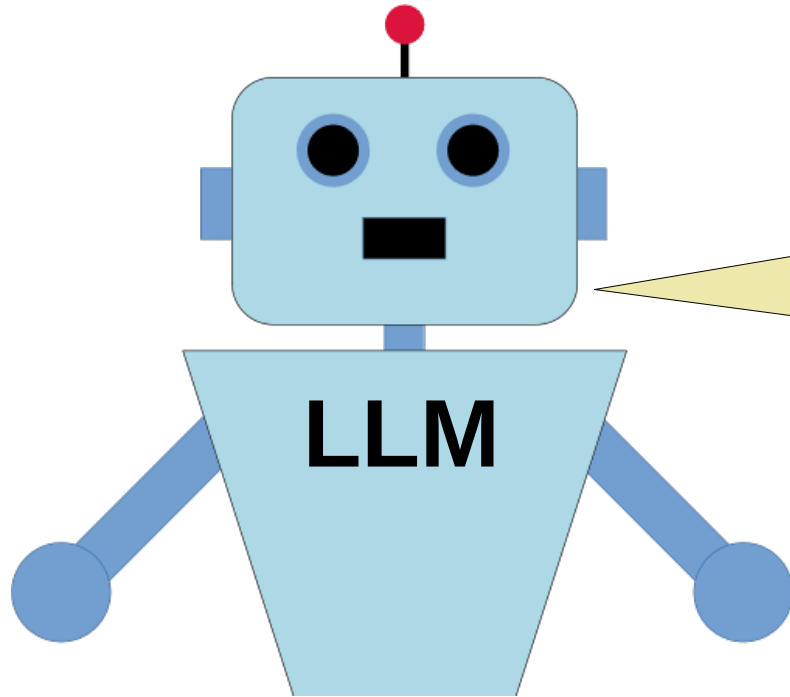


The Hallucination

What is a XML
parser? Try
anything, I
guess...



The Infection



Doing this:

```
pip install fastxmlparser
```

NOTE: “fastxmlparser” is my own fictitious package name used here only as an example!

The Malware

fastxmlparser



NOTE:
“fastxmlparser”
is my own
fictitious
package name
used here only
as an example!



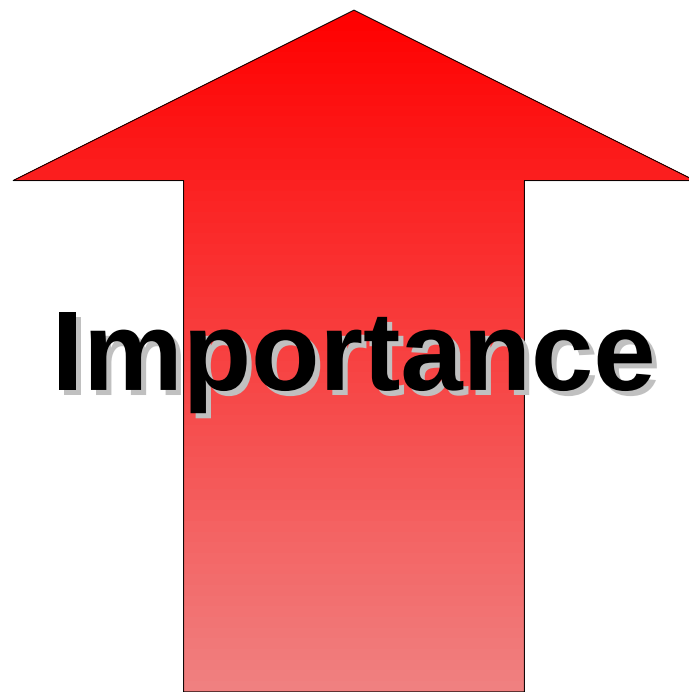
InfoStealer:

Creds
Keys
Sessions
Tokens
etc.

AI accelerates



Vulnerability Management



Classic Patch Management

AI is now rendering our
“classic patch
management”
schedules inadequate

Monthly To-Do List:

Scan

Prioritize

Schedule

Patch

Re-scan

AI Guardrails

- Data Protection
- Control Access & Govern AI Behavior
- Explainability and Results Testing
- Maintain Transparency for Audit-ability
- Continuously Monitor Risk

Bringing it Home

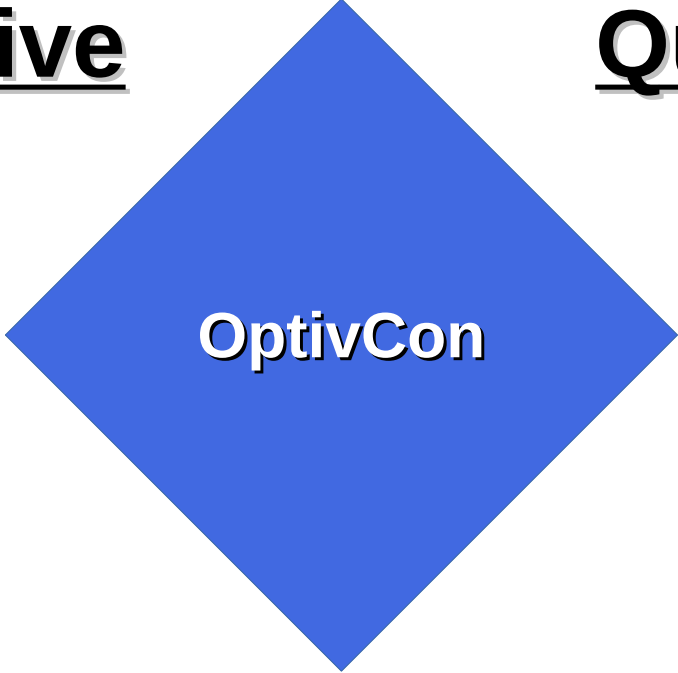
Lets wrap things up...



Have the Conversations

Provocative

Questions



OptivCon

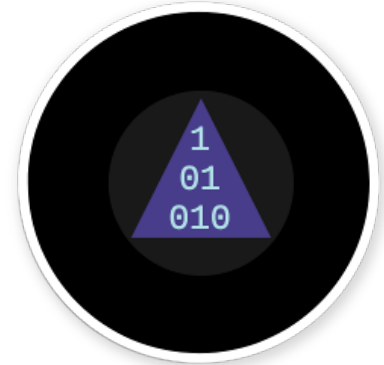
Guardrail Questions

- What condition must never occur?
- Where is the earliest prevention point?
- Which telemetry detects a failure?
- What are our exceptions' processes?
- Who owns each piece?

Q & A



Who?
What?
When?
Where?
Why?
How?



OptivCon Columbus



Thank you for
attending
"Building your
Guardr' AI'ls!"

